

## MODULE 6 OWASP A05 Injection — SQLi, XSS, Command Injection, SSRF

🕒 16:30 – 17:30 · Day 1

OWASP A05

### 🕒 TIMING:

50 minutes. 5 min injection principle, 10 min SQLi (Juice Shop), 25 min XSS Game levels 1–4, 5 min SSRF concept, 5 min BBC reflections

### Activity 1 — SQL Injection (Juice Shop) (5 min)

#### 📋 DELEGATE INSTRUCTIONS:

JUICE SHOP SQLi:

Open <http://localhost:3001> → Account → Login

Email field: ' OR 1=1-- (single quote, space, OR, space, 1=1, double-dash)

Password: anything

Result: you are logged in as admin.

Now try a more targeted SQLi:

Email: `admin@juice-sh.op'--`

This logs you in AS admin (knowing only the email, not the password).

### Activity 2 — XSS Game (15 min)

#### 📋 DELEGATE INSTRUCTIONS:

Open Firefox. Navigate to: <http://xss-game.appspot.com> (or offline copy at `~/xss-game`)

Complete levels 1 to 4. For each level, record:

- What payload worked?
- Where did the input land in the HTML output?
- Did the payload appear in ZAP's HTTP requests?

KEY FINDING for Level 3:

The payload is delivered via the URL fragment (#)

Fragment identifiers NEVER get sent to the server

ZAP will show NO evidence of this attack — it is invisible to the server

This is DOM-based XSS — it lives entirely in the browser's JavaScript

This is the same blind spot that affects WAFs (Web Application Firewalls).